LECTURE NOTES REPORT

CS50's Introduction to Cybersecurity

Lecture 0 | Securing Accounts

Lecture Overview

This lecture introduces the foundational concepts of digital account security. It covers how authentication works, the mechanics of common attack strategies, quantitative analysis of password strength, NIST security guidelines, multi-factor authentication approaches, and modern solutions such as password managers and passkeys.

1. Security — Foundations of Digital Authentication

Just as a physical key controls access to a building, digital credentials control access to online accounts. The core building blocks of account security are:

- Authentication: The process of proving your identity to a system — typically via credentials only you should know or have.
- Authorization: Once identity is verified, the system grants access to the resources you are permitted to use.
- Usernames: A public identifier that tells the system who you claim to be.
- Passwords: A secret shared only between you and the system that confirms your claimed identity.

The implicit security guarantee is that only the legitimate user can supply both correct username and password simultaneously. Any attack that circumvents this guarantee undermines account security.

Key Insight — Security vs. Usability Trade-off

Every security measure involves a trade-off with usability. A highly secure system may become difficult or tedious to use, leading users to adopt workarounds that reduce security. Effective security design finds the right balance for a given context and risk profile.

2. Defending Against Attacks — Password Strength Analysis

The primary defense against brute-force attacks is increasing password complexity. The relationship between character set size, password length, and total possible combinations determines how long an attacker must spend guessing:

Character Set	4-Char Options	Total Combinations	Practical Risk

Digits only (0–9)	10	10,000	Cracked in milliseconds
Letters only (a–z, A–Z)	52	~7.3 million	Cracked in seconds
Letters + Digits (62 chars)	62	~14.8 million	Cracked in under a minute
Letters + Digits + Punctuation (~95)	~95	~81.4 million	Much longer — but still feasible

The core principle: raising the computational cost for an attacker — even by seconds — is meaningful. Adversaries operating at scale will prioritize easier targets. Longer passwords with larger character sets are exponentially harder to crack. The formula for total combinations is:

```
Combinations = (Character Set Size) ^ (Password Length)
```

3. NIST Guidelines — Authoritative Password Recommendations

The National Institute of Standards and Technology (NIST) publishes widely adopted best practices for password and authentication security. Key recommendations include:

- Minimum length: Passwords (memorized secrets) should be at least 8 characters long.
- Maximum length: Verifiers should support passwords up to 64 characters, accommodating passphrases.
- Character support: All printable ASCII characters and Unicode symbols should be permitted.
- Blacklist enforcement: Verifiers should compare new passwords against breached password lists, common dictionary words, repetitive sequences, and context-specific terms.
- No hints: Systems should not offer password hints to unauthenticated users, as hints reduce entropy.
- No forced rotation: Periodic mandatory password changes are discouraged — they tend to produce weaker, predictable passwords (e.g., Password1 → Password2).
- Failed attempt throttling: Systems should limit and lock out repeated failed authentication attempts to prevent automated brute-forcing.

4. Two-Factor & Multi-Factor Authentication (2FA / MFA)

MFA substantially reduces account compromise risk by requiring verification from two or more independent factor categories. Even if one factor is stolen, the attacker still cannot gain access without the other(s).

Factor Type	Description	Common Examples

Knowledge	Something only you know	Password, PIN, security question
Possession	A device only you have	OTP app, hardware key fob, SMS code
Inherence	Something unique to you biologically	Fingerprint, face recognition, voice

Best practice is to combine at least two of the three factor types. The most common and accessible combination is Knowledge (password) + Possession (authenticator app or OTP device).

5. One-Time Passwords (OTP) — Mechanism & Security Tiers

OTPs are time-limited codes generated fresh for each authentication event. They are immune to password reuse attacks because they expire immediately after use. However, not all OTP delivery methods offer equal security:

OTP Method	How It Works	Security Level
Hardware Key Fob	Dedicated physical device generates time-based codes	High — requires physical theft to compromise
Authenticator App (e.g., Google Auth)	Secure app on your phone generates TOTP codes	High — device-bound, no interception vector
SMS / Text Message OTP	Code sent to your registered phone number	Low-Medium — vulnerable to SIM swapping attacks

6. Common Attack Vectors — A Comprehensive Overview

Understanding how attacks work is the first step to defending against them. The following table summarizes the primary attack methods covered in this lecture:

Attack Type	How It Works	Defense Strategy
Dictionary / Brute-Force	Tries large lists of common or all possible passwords	Long, complex, unique passwords
Keylogging	Malicious software records every keystroke	Use trusted devices; run security software
Credential Stuffing	Reuses leaked username/password pairs on other sites	Never reuse passwords across services
Social Engineering	Manipulates people via trust or pressure to reveal credentials	Verify identity before sharing any information

Phishing	Fake websites/emails impersonate trusted services	Type URLs manually; never click blind links
Machine-in-the-Middle	Intercepts traffic between user and destination	Use encrypted connections (HTTPS/TLS)
SIM Swapping	Clones your SIM card to receive your SMS OTPs	Use authenticator app instead of SMS for 2FA

6.1 Keylogging — Insider Threat on Your Own Device

- Keylogging captures every keystroke — including usernames, passwords, and OTPs — by running silently in the background.
- It is installed via malware, often through phishing emails, malicious downloads, or compromised websites.
- Mitigation: Only authenticate on devices you fully control and trust; keep security software updated.

6.2 Credential Stuffing — Scale Exploitation of Leaked Data

- When a website is breached, the leaked credential database (usernames + passwords) is tested against other popular services.
- This attack is automated and operates at massive scale, making password reuse extremely dangerous.
- Mitigation: Use a unique, randomly generated password for every service — facilitated by a password manager.

6.3 Social Engineering — Human Layer Exploitation

- Rather than exploiting software, social engineering exploits human trust, authority, and psychological pressure.
- Attackers may impersonate IT staff, employers, banks, or other trusted parties to extract credentials or personal security information (pet names, birthdays, mother's maiden name — common security question answers).
- Mitigation: Verify the identity of anyone requesting sensitive information through a separate, trusted communication channel.

6.4 Phishing — Social Engineering via Technology

- Phishing is a technologically-delivered form of social engineering: fake login pages or emails mimic trusted services to capture credentials.
- A phishing page may be pixel-perfect copies of legitimate sites (e.g., Google, your bank), distinguishable only by URL inspection.
- Mitigation: Never follow links in emails to login pages. Navigate directly to services by typing the URL manually in your browser.

  - Additional defense: Password managers and passkeys automatically detect domain mismatches and will not autofill on phishing sites.

6.5 Machine-in-the-Middle — Network Infrastructure Attacks

- Sophisticated attackers can compromise the routers and switches between a user and a server, intercepting and potentially modifying traffic.
- This is particularly concerning on public Wi-Fi networks and within compromised ISP infrastructure.
- Mitigation: Always verify HTTPS/TLS connections; consider using a trusted VPN on untrusted networks.

7. Defensive Tools & Solutions

7.1 Single Sign-On (SSO)

- SSO allows users to authenticate once with a trusted Identity Provider (e.g., Google, Apple, Microsoft) and then access multiple third-party services without separate credentials.
- Benefits: Reduces the number of passwords to manage; trusted IdPs have strong security infrastructure; simplifies the login experience.
- Trade-off: If the central SSO account is compromised, all linked services become vulnerable — making strong security on the primary account critical.

7.2 Password Managers

- Password managers generate, store, and autofill complex, unique passwords for every service — eliminating the need to remember or manually type passwords.
- Unlike browser-built-in password saving (a simpler tool), dedicated password managers work across all browsers and devices and typically offer additional features.
- Many password managers detect known phishing sites and will not autofill on unrecognized domains — providing an additional layer of protection.
- Trade-off: The master password becomes a critical single point of failure ("all eggs in one basket"). Protect it with a strong, memorable passphrase and enable MFA on the manager itself.

Password Manager — Best Practice

Choose a reputable, audited password manager (e.g., Bitwarden, 1Password). Use a strong, unique master password — ideally a multi-word passphrase. Enable MFA on the manager account. Store the master password in a secure, offline location as a backup.

7.3 Passkeys — The Future of Authentication

- Passkeys are a phishing-resistant, cryptography-based authentication standard developed by the FIDO Alliance and adopted by major platforms (Apple, Google, Microsoft).
- They operate on asymmetric cryptography: a public key is stored on the server; a private key is stored securely on your device and never transmitted.
- Authentication occurs via local device verification (biometric or PIN) — no password is ever sent over the network, eliminating phishing and credential stuffing attacks entirely.
- The user experience is seamless: unlock your device, and you are authenticated — no password to remember or type.
- Note: Full understanding of the cryptographic mechanism requires knowledge of public-key cryptography, covered in later lectures.

8. Summary — Key Takeaways

This lecture established the conceptual and practical foundation for digital account security. The central insights are:

- Security is always a trade-off: Every security measure has a usability cost. Good security design balances protection with practicality for the given risk context.
- Password strength is mathematical: Complexity (character set size) combined with length determines resistance to brute-force attacks. The formula is (set size)^(length).
- NIST guidelines are the authoritative standard: Minimum 8 characters, no forced rotation, block breached passwords, throttle failed attempts.
- MFA dramatically raises the bar: Combining knowledge, possession, and/or inherence factors means a stolen password alone cannot compromise an account.
- Know the attack landscape: Brute-force, keylogging, credential stuffing, social engineering, phishing, machine-in-the-middle, and SIM swapping each have distinct mechanisms and defenses.
- Human behavior is the primary attack surface: Most successful attacks exploit human trust and inattention rather than technical vulnerabilities. Awareness is itself a security control.
- Use the right tools: Password managers solve the uniqueness-memory trade-off. SSO reduces credential sprawl. Passkeys, when fully adopted, will eliminate passwords altogether.

Source: CS50's Introduction to Cybersecurity — Lecture 0 Notes | cs50.harvard.edu/cybersecurity/notes/0 | Harvard University